Bug Bounty Programs in the AI Era: How Does Platform Anti-Spam Friction Affect Vendor Profitability?

Haruki Oyama[1,a)] Masato Kamba[2,b)] Koshi Ota[2,c)]

Abstract: Since 2023, bug bounty platforms have introduced participation rules, such as proof-of-concept mandates, against a flood of AI-generated low-quality submissions. The platforms set these rules, but vendors running programs on them bear the cost when a vulnerability goes unreported and gets exploited. We ask whether the rules benefit the vendors they are meant to protect. Adding to Gal-Or, Hydari, and Telang's 2024 model a vendor triage cost per report reviewed and a participation cost paid in effort by the researchers reporting vulnerabilities, we locate a threshold in an effective triage-burden parameter, which captures the vendor's processing burden per unit of aggregate search effort, with the rules lowering profit below it and raising it above. Because attackers never use the platform, the participation cost falls on researchers alone and fewer take part. Bug-finding coverage falls and breach damage rises, which costs the vendor, while its triage bill falls, which helps.

Keywords: bug bounty, vulnerability disclosure, security economics, platform policy

1. Introduction

Bug bounty programs, market mechanisms in which software vendors pay external researchers for discovering and reporting vulnerabilities, have become a standard component of vulnerability management at major firms [1], [2]. Two developments have recently reshaped the cost structure of this market. The broad availability of large language models and AI-assisted code analysis tools has lowered the effort cost of vulnerability discovery. Fang et al. [3] show that LLM agents can autonomously exploit one-day vulnerabilities, and the volume of low-quality, often AI-generated submissions has risen with the same tools [4], [5]. Between 2023 and 2026, major bug bounty platforms responded with participation rules: proof-of-concept mandates, submission caps, deposits, and identity gates. The platforms set these rules, but the vendors running programs on them bear the cost when a vulnerability goes unreported and is exploited. We ask whether the rules benefit the vendors they are meant to protect. The answer matters to any vendor deciding how much to rely on a platform that imposes them.

We answer inside the game-theoretic framework of Gal-Or, Hydari, and Telang [1], which models the interaction among the vendor, white-hat researchers, and black-hat attackers as a two-stage Stackelberg game and derives the vendor's expected profit from operating a program. That framework treats the platform as implicit. It represents neither the participation costs the platform's rules impose on researchers nor any cost to the vendor of processing the reports it receives. The same gap runs through the adjacent theoretical literature [6], [7], while the empirical literature characterizes platform dynamics descriptively without formalizing these costs [2], [8].

We add two components. The first is a participation cost that anti-spam rules impose on white-hat researchers, together with a free-entry margin under which a researcher joins only when the expected payoff from searching covers this cost. The number of participating experts is then settled by the researchers' own participation decisions. The second is a triage cost on the vendor, the burden of processing the submissions the program generates, which enters the vendor's profit alongside the damage and bounty terms.

The central finding is that the friction moves vendor profit through two channels. It falls on the white-hat researchers who protect the vendor by finding and reporting severe bugs before attackers can exploit them, but it does not reach the attackers, who never participate in the platform. As the pool thins, attackers face weaker competition and succeed more often, so coverage falls and expected breach damage rises. This channel always runs against the vendor. The thinner pool also submits fewer reports, so the triage bill falls. This channel always runs in its favor. Which channel dominates depends on the vendor's effective triage burden, and the model locates the threshold at which the net effect

[1] Waseda University, Sako Laboratory
[2] Nyx Foundation
[a)] harukioyama0409@gmail.com
[b)] masato.kamba@nyx.foundation
[c)] cassiopeia01620@gmail.com

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

changes sign. The threshold rises with the vendor's breach cost, so anti-spam friction is most damaging to the vendors with the most to lose. The result holds for the vendor whose posted bounty stays fixed when the rules change. A vendor that continuously re-optimizes its bounty never gains from the friction at the calibrated parameter values, because it can thin the pool itself, and its bounty response recovers only part of the lost coverage.

2. Background and Related Work

2.1 The Platform Layer and the AI Shift

Most vendors do not run their bug bounty programs directly. They contract with specialized platforms, including HackerOne, Bugcrowd, Immunefi, Code4rena, Sherlock, Cantina, Intigriti, and YesWeHack.[*1] These platforms operate as two-sided markets, meaning they connect two groups that each benefit from the other's presence, vendors on the demand side and researchers on the supply side, and they provide submission intake, triage (the review and validation of incoming reports), dispute resolution, and payment processing [8], [9]. The institutional feature that matters here is the division of control. The vendor specifies the program's scope and bounty amounts, but the platform sets the participation rules that determine which researchers can enter and which submissions reach the vendor.

The cost structure of vulnerability discovery shifted with the broad availability of large language models. CVE publication reached record levels in 2025 [10], and by 2025 platforms reported that the same tools flooded their queues with low-quality submissions. GitHub stated that new tools, including AI, have lowered the barrier to entry [11], and Bugcrowd cited a 334-percent increase in queue volume over three weeks [4]. The response is documented in a series of public policy changes between 2023 and 2026. GitHub introduced stricter proof-of-concept and scope-enforcement rules for its program in May 2026, requiring a working demonstration of each reported bug and stricter adherence to the declared program scope [11]. Immunefi capped newly registered researchers at one report per twenty-four hours until their first paid report [12]. Cantina added per-bounty deposits, money a researcher stakes on each submission, which the platform keeps for spam and low-effort AI reports and refunds on good-faith rejections [13]. Code4rena introduced signal-based submission caps, where a researcher's signal is a score the platform computes from their track record of valid reports and a low score means stricter limits [14]. Sherlock has withheld payouts since July 2023 from researchers below cumulative validity thresholds, meaning a minimum count and share of valid reports across an account's lifetime. This rule predates the AI flood [15]. Bugcrowd announced permanent bans in March 2026 for submission farming, the practice of mass-submitting low-effort reports in the hope that some pay out [4]. HackerOne's Node.js program went furthest, blocking new researchers with no signal from submitting at all [16]. Two of these cases, GitHub's and Node.js's, are program-level actions by a vendor, not platform-level rules, and they show the same family of rules appearing on both sides of the division of control.

What matters for the model is who pays these costs and who does not. Every rule above raises the cost of taking part for researchers, and none of them raises the cost for attackers, who never use the platform. Some rules bind only new researchers, while deposit requirements, proof-of-concept mandates, and payout-reserve thresholds bind established experts as well, and it is this latter kind that the participation cost of Section 3 stands for. The evidence that such costs reach capable researchers is direct. GitGuardian reported leaked private keys closed as informative, a triage label that acknowledges a report but pays no bounty, because triagers demanded exploitation proofs that would have crossed into active attack [17], and the researcher-side literature documents these burdens systematically [18]. The curl project ended its bounty in January 2026 after an AI-generated report flood [19], and its maintainer had acknowledged months earlier that even reducing the reward removes the traction for some professional and highly skilled researchers [5].

2.2 The Gal-Or, Hydari, and Telang Model

Our analysis builds on the game-theoretic model of Gal-Or, Hydari, and Telang [1], restated here in the order the game is played. There are four types of agents. The vendor releases the software and pays the bounties. Expert white-hat hackers, n of them, are researchers who report what they find to the vendor in exchange for the bounty, and they can search for both severe and non-severe bugs, where severe bugs are the ones that map to the High or Critical ratings of the Common Vulnerability Scoring System (CVSS). Non-expert white-hats, l of them, search only for non-severe bugs, since severe bugs are assumed too costly for them per unit of effort. Black-hat hackers, m of them, exploit what they find for illicit gain, and they search only for severe bugs, because non-severe bugs are assumed to be worth almost nothing to an attacker.

The game is a Stackelberg game with two stages, meaning one side commits first and the others respond. In the first stage the vendor commits to a release time t and to two bounties, p_s for a severe bug and p_{ns} for a non-severe one. In the second stage the hackers choose how hard to search, and their choices form a Nash equilibrium given the vendor's commitment. The race for each bug is what connects the two sides. Only the first valid report of a bug is paid, and once a black-hat exploits a bug the vendor identifies and patches it, so a bug that an attacker reaches first is closed to the researchers. Searching is costly, with effort costs quadratic in effort and severe bugs costing more per unit of effort than non-severe ones, which the cost weights $c_w > 1$ for white-hats and $c_b > 1$ for black-hats capture.

[*1] HackerOne (`hackerone.com`), Bugcrowd (`bugcrowd.com`), Immunefi (`immunefi.com`), Code4rena (`code4rena.com`), Sherlock (`sherlock.xyz`), Cantina (`cantina.xyz`), Intigriti (`intigriti.com`), and YesWeHack (`yeswehack.com`).

© 2026 Information Processing Society of Japan

How likely each side is to reach a bug first depends on everyone's effort. Write $s \equiv n+m$ for the number of severe-bug searchers, α_s for each expert's effort on severe bugs, and μ_s for each black-hat's effort, where hackers of the same type choose the same effort in equilibrium. Each hacker chooses its own effort taking all other hackers' efforts as given, and the success probabilities below are evaluated at that type-symmetric profile. The probability that a given expert or a given black-hat is the first to a severe bug is its own effort measured against the effort of its rivals in the race,

$$\mathbb{P}^s_{ie} = \frac{(s-1)\,\alpha_s}{s\,[(n-1)\alpha_s + m\mu_s]}, \qquad \mathbb{P}^s_{ib} = \frac{(s-1)\,\mu_s}{s\,[n\alpha_s + (m-1)\mu_s]}.$$

This is the multiplicative ratio form of the model, given in their Appendix A, and we work with it throughout because in the additive main-text form a hacker's optimal effort does not respond to rivals' effort, so that form cannot generate the cross-side substitution our mechanism runs on. We also work within their severe-focus case, in which experts allocate effort only to severe bugs.

Each hacker weighs the expected reward against the effort cost. An expert chooses α_s to maximize $K_s(t)\,\mathbb{P}^s_{ie}\,(r_s + p_s) - \frac{1}{2}c_w\alpha_s^2$, where r_s is the reputational gain from a valid report and $K_s(t)$ is the probability that a severe vulnerability is still present when the software is released at time t, decreasing and convex in t. A black-hat chooses μ_s to maximize $K_s(t)\,\mathbb{P}^s_{ib}\,W - \frac{1}{2}c_b\mu_s^2$, where W is the illicit gain from exploiting the bug, defined net of the legal risk of being caught.

The vendor's expected profit is their Equation 14, which we write in full,

$$\Pi = R(t) - K_s(t)\,m\,\mathbb{P}^s_{ib}\,TC_s - K_s(t)\,n\,\mathbb{P}^s_{ie}\,p_s \\ - K_{ns}(t)\,l\,\mathbb{P}^{ns}_{ine}\,p_{ns} - K_{ns}(t)\,TC_{ns}\,[1 - l\,\mathbb{P}^{ns}_{ine}]\,.$$

The first term $R(t)$ is the revenue from releasing at time t. The four remaining terms are the costs, in order. The expected damage from black-hats, since $m\,\mathbb{P}^s_{ib}$ of the remaining severe bugs are reached by attackers first and each costs the vendor TC_s. The severe bounty bill, since $n\,\mathbb{P}^s_{ie}$ of them are reported first by experts and each earns p_s. The non-severe bounty bill, where $K_{ns}(t)$ is the probability that a non-severe bug remains at release and $\mathbb{P}^{ns}_{ine}$ is the probability that a given non-expert is the first to it. And the cost of non-severe bugs that escape the program entirely and are discovered by users instead, at TC_{ns} each, with TC_s much larger than TC_{ns}.

Two of their results anchor ours. Raising the severe bounty p_s raises white-hat success and lowers black-hat success, because the two sides race for the same bugs (their Proposition 1). And a program with positive optimal bounties is more profitable than no program (their Proposition 2).

2.3 The Gap

Böhme [20] establishes vulnerability information as a tradeable economic object in a market with structural failures, and Kannan and Telang [21] show that an unregulated vulnerability market can perform worse than coordinated disclosure. On the empirical side, Sridhar and Ng [2] estimate from over 3,800 HackerOne program-months a low median supply elasticity with respect to bounty amounts, interpreting researchers as motivated mainly by things other than money. Zrahia, Gandal, Markovich, and Riordan [8] treat the platform as a two-sided marketplace and show that the COVID-19 supply expansion produced a disproportionate increase in duplicate valid submissions, diluting the expected reward for valid work. Allodi [22] documents that underground markets price exploits at levels comparable to or above legitimate bounties and refresh their stock slowly. Closer to the platform layer, Wachs [9] analyzes platforms as transaction-cost intermediaries that make the market possible, and Zhao, Laszka, and Grossklags [23] measure platform ecosystems and evaluate policy instruments for them. None of these formalizes how participation costs imposed by the platform itself affect the market equilibrium. Laszka, Zhao, and Grossklags [24] model invalid-report validation and organizational processing costs in bug-bounty platforms, so they come closest to pricing report handling. Their model has no race for severe bugs between researchers and attackers. Ours differs by embedding a vendor-side triage burden and a free-entry participation margin into that race, which is what lets us study the opposing effects of participation friction on aggregate coverage and triage expenditure. The two theoretical contributions closest to ours share the same gap. Li and Liao [6] model defender–attacker interaction without a platform layer, and Zhou, Ma, and Feng [7] model a platform's decision whether to launch a program for third-party software, in which the participation costs a running program imposes on researchers are not the object. Within the race model we build on, the vendor's profit function counts only successful discoveries and carries no processing cost. This paper addresses both omissions.

3. Model

3.1 Friction as a Single Lever

We abstract the family of anti-spam rules into a single parameter, a participation cost $c_f \geq 0$ borne by white-hat researchers, which we call the friction. The cost need not be monetary. It may be the time required to produce a working proof of concept, a deposit placed at risk, the disclosure of one's identity, or a cap on how many reports one may submit. What these policies share is that they raise the burden of taking part, and c_f is the common measure of that burden. The bundled burdens differ in kind and in who bears them, since a deposit binds harder on a researcher without conventional banking and an identity gate excludes researchers in some jurisdictions outright [18]. The parameter acts through a single margin, the size of the expert white-hat pool, and we treat the platform's choice of c_f as an input. The AI-era surge in submission volume that motivated the rules is context for the analysis, not a variable

© 2026 Information Processing Society of Japan

in it.

3.2 The Participation Margin

This section derives how the researcher pool is determined. The order of moves has three steps. The vendor posts its bounty, researchers observe the bounty and the friction and enter until the marginal researcher is indifferent, and the hackers then choose effort taking the pool as settled. Write $\pi_W(n; p_s)$ for an expert's expected payoff from taking part when the pool holds n experts at the posted bounty p_s, the expected reward for a valid report on a remaining severe bug, minus the effort cost of searching (the exact expression is in Appendix A.1). Following the standard free-entry formulation of [25], a researcher joins when the payoff covers the friction, so the marginal researcher is indifferent,

$$\pi_W(n^*; p_s) \;=\; c_f.$$

This condition picks out a single pool size at each posted bounty, and raising the friction shrinks it. Adding an expert splits the same prize among more rivals, so the payoff π_W falls as the pool grows. We show this monotonicity analytically up to a stated, negligible exception (Appendix A.1.3). When the platform raises c_f, the payoff at the incumbent pool no longer covers the friction, so researchers leave until the margin is restored at a smaller n^*. The pool empties only when the friction reaches the payoff of a lone searcher, $c_f \;\geq\; \pi_W(1; p_s)$. One behavioral assumption matters for what follows, and we state it as an assumption, not a fact. The posted bounty is set for coverage, without the triage burden priced in, and it stays posted when the platform changes its rules. Section 4.2 examines the vendor that continuously re-optimizes its bounty instead, and the answer changes there.

The friction reaches only one side of the market. Attackers never use the platform, because exploitation requires no submission, so they bear none of the friction and m stays fixed. Two qualifications bound this premise. Identity-based instruments reach anyone maintaining a platform identity, so an attacker who also holds a researcher account pays part of the friction. The asymmetry is exact for effort, deposit, and workload costs, and approximate for identity gates. The premise also needs attackers to find the legitimate channel unattractive at the margin, and the calibration supports this. Underground pricing comparable to legitimate bounties with a slow refresh cycle [22] means a marginal attacker gains little by switching sides for a bounty the vendor keeps small. Everything below depends on this asymmetry.

One exact consequence of the entry margin is worth stating in words, because Section 4.1 uses it. At equilibrium an expert's gross reward equals exactly twice the effort cost of searching, so the payoff from taking part equals the effort cost itself, and a higher friction makes each surviving researcher search *harder*, even as the pool thins. The derivation is in Appendix A.1.3. Aggregate coverage $n\alpha_s$ still falls, and it is the aggregate that protects the vendor.

With the pool size settled by the researchers' own participation decisions, the vendor's problem gains the second new ingredient, the cost of processing the reports the pool submits.

3.3 The Vendor's Problem with Triage

Reports have no representation in Gal-Or, Hydari, and Telang's game, which counts only successful discoveries, so nothing in the equilibrium corresponds to the flow of reports a vendor must process. Pricing triage therefore requires an assumption. We assume that the report flow scales with the pool's aggregate search effort $n\alpha_s$. The coefficient β captures the effective triage burden per unit of aggregate search effort, combining the processing cost of a report with the number of reports one unit of search effort generates. We keep β at this level of abstraction because the two components cannot be told apart in the model. This is an assumption, not a derivation, and Section 5 examines it. Two of its properties can be stated without new computation. First, because β aggregates the processing burden and report-generation intensity into a single model parameter, the location of the threshold of Section 4.1 depends on numbers only the model defines. Its existence and its comparative statics are what the results say about the real world. Second, the linear form is conservative for the coverage result in a specific sense. If the true flow is convex in the pool, as the duplicate-dilution evidence of [8] suggests, the triage saving from a pool cut is larger than the linear estimate, so the reported threshold is an upper bound, while the region where coverage dominates at low β is unaffected, since the triage term vanishes with β under any curvature. The vendor's expected cost has three terms,

$$C \;\equiv\; K_s(t)\,[\,m\,\mathbb{P}^s_{ib}\,TC_s \;+\; n\,\mathbb{P}^s_{ie}\,p_s\,] \;+\; \beta\,n\,\alpha_s,$$
$$\Pi = R - C - \text{const},$$

where const collects the non-severe terms of the profit function, which do not depend on n. The vendor's other instruments, the release time t and the non-severe bounty p_{ns}, are held at their optimal values throughout. The three terms of C are the three ways the pool costs the vendor money. The first is the expected black-hat damage. The second is the severe bounty bill. The third is the new triage term, the cost of processing the reports the pool submits. We evaluate the friction's effect under two vendor behaviors, both computed in Appendix A.1. The posted-bounty vendor sets its bounty once, as the optimum when the triage burden is not priced, and leaves it posted when the friction changes. The re-optimizing vendor re-solves its bounty after the rule change, anticipating how the bounty steers entry through the participation condition of Section 3.2. The main analysis uses the first. Section 4.2 uses the second.

4. Results

The results follow the friction in two steps, first into the size of the researcher pool and then into the vendor's profit, and Figure 1 shows the first step.

© 2026 Information Processing Society of Japan

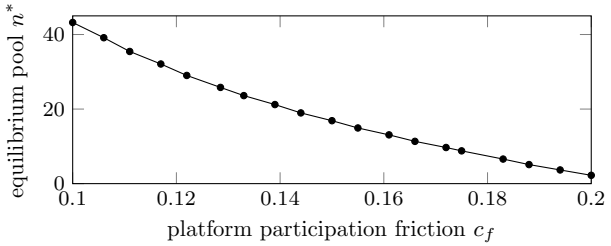


Fig. 1 As platform participation friction c_f rises, the equilibrium expert pool n^* falls along the entry margin of Section 3.2 at the posted bounty $p_s = 20.46$ of the base calibration.

Table 1 Equilibrium under the friction rise, posted-bounty vendor, base calibration. The pool falls from 25.81 to 8.79 at the posted bounty 20.46 in every row. ΔC is the cost change from the friction rise, so a positive value means the friction hurts.

β	$C(c_f^{lo})$	$C(c_f^{hi})$	ΔC	$\Pi(c_f^{lo})$	$\Pi(c_f^{hi})$
0.00	13.100	14.277	+1.177	36.900	35.723
0.20	14.950	15.013	+0.062	35.050	34.988
0.40	16.801	15.748	−1.053	33.199	34.252
0.60	18.651	16.483	−2.168	31.349	33.517
0.80	20.502	17.218	−3.283	29.499	32.782

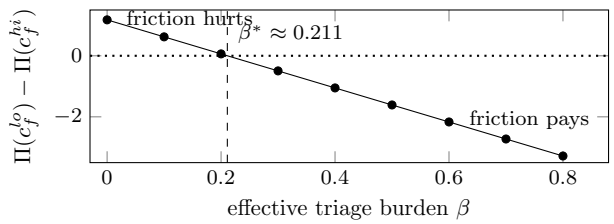


Fig. 2 The profit advantage of the low-friction state over the high-friction state, at nine values of the effective triage burden β, base calibration, posted-bounty vendor. The points at the five tabulated burdens are exact differences of the Table 1 values, and the remaining four lie on the same line. Above zero the friction hurts the vendor. Below zero it pays. The dashed line marks the threshold $\beta^* \approx 0.211$.

4.1 A Threshold in the Triage Cost

Whether the rules help or hurt the vendor depends on the effective triage burden β. The units caveat of Section 3.3 applies here. Table 1 evaluates the equilibrium at the base calibration ($m = 10$, $K_s(t) = 0.5$, $c_w = c_b = 2$, $r_s = 10$, $W = 96$, $TC_s = 30$, an example parameterization chosen for comparability with the source model's numerical examples, not from micro-data), under a rule change that raises the friction from $c_f = 0.1285$ to $c_f = 0.1750$, values chosen so the pool falls from 25.8 to 8.8 at the posted bounty 20.46. At zero triage burden the friction hurts. The thinner pool raises the expected damage, and there is no triage bill to save. The vendor's cost rises by 1.18. As β rises, the triage saving from the thinner pool grows linearly, while the added damage does not depend on β. The two cross at $\beta^* \approx 0.211$, below which the friction costs the vendor and above which it pays. This is the break-even point of the calibrated numerical model, expressed in effective triage-burden units, not a directly measured dollar cost per report. Figure 2 shows the profit difference.

The threshold is not a feature of one parameterization.

Table 2 Equilibrium under the friction rise, re-optimizing vendor, base calibration at $\beta = 0.20$. Entries use the unrounded friction values ($c_f^{lo} = 0.12846$, $c_f^{hi} = 0.17500$).

	p_s^*	n^*	α_s	μ_s	$\mathbb{P}_{ie}^s$	C	Π
c_f^{lo}	17.338	14.989	0.3584	1.3291	0.0188	14.558	35.442
c_f^{hi}	19.673	6.318	0.4183	1.4421	0.0236	14.993	35.007

Across thirteen perturbations of the base calibration, spanning $W \in \{48, 200\}$, $r_s \in \{2, 30\}$, $TC_s \in \{10, 100, 200\}$, $K_s \in \{0.2, 0.9\}$, both cost multipliers, and a joint shift in W and r_s, a positive threshold exists in all fourteen parameter sets, so the coverage channel dominates at low triage burden throughout (Appendix A.1.4). Two mechanisms produce the flips, and they should not be pooled. In nine of the fourteen the thinned pool survives at the posted bounty, and the triage saving, linear in β, overtakes the fixed damage penalty. In five ($W = 48$, $r_s = 30$, $TC_s = 100$, $TC_s = 200$, $c_w = 1.2$) the posted bounty cannot sustain the thinned pool under the higher friction, the pool collapses, and the flip compares a low-friction state whose triage bill has grown past the cost of having no program at all, the collapsed high-friction state with unmitigated damage at $n^* = 0$. Our claim rests on the first mechanism, and the second we report but do not emphasize.

4.2 When the Vendor Re-Optimizes

The threshold above belongs to the posted-bounty vendor. The other behavior answers differently. A vendor that re-solves its bounty after the rule change, anticipating how the bounty steers entry, has no region where the friction pays at the base calibration. The cost increase from the same friction rise falls from +0.92 at $\beta = 0$ to exactly zero at $\beta_0 = 0.3024$ and never turns negative, on a 0.001 grid refined by bisection, because any thinning the vendor wants it can produce by lowering its own bounty, so the friction, which makes every pool size costlier to sustain, has nothing to offer. Past β_0 the optimal bounty attracts no entry and the program effectively shuts down. We do not read realism into that case, since real programs degrade gradually and vendors hold margins our model freezes. One exception survives this shutdown result: when the friction is low enough that even a zero bounty attracts entry, the vendor cannot thin the pool itself, and a genuine flip survives (at $TC_s = 10$ with $c_f^{lo} = 0.017$, $\beta^* = 0.2287$).

The re-optimizing vendor's bounty response recovers part of the coverage but not the profit. Table 2 reports the equilibrium at $\beta = 0.20$. The optimal bounty rises from 17.34 to 19.67, and preserves 42 percent of the pre-change pool, which would otherwise collapse to zero at the old bounty. The cost still rises, from 14.558 to 14.993. The bounty buys back some of the pool. It does not buy back the loss.

There is a reason a platform might not see the harm. As the pool thins, the surviving experts face fewer rivals and, by the identity of Section 3.2, each searches harder, so each wins races more often. The per-hunter success probability $\mathbb{P}_{ie}^s$ rises from 0.0169 to 0.0230 at the posted bounty.

© 2026 Information Processing Society of Japan

Per-hunter dashboards, mean reward per active researcher, and win rates all improve even as aggregate coverage falls. A policy that harms the hosted vendor can look, from the platform's vantage, like one that is working.

4.3 High-Stakes Vendors Lose Most

For the posted-bounty vendor, the stakes decide the size of the loss and the threshold's location. At zero triage burden the cost increase from the friction rise is +0.51 at $TC_s = 10$, +1.18 at the base $TC_s = 30$, and +11.01 at $TC_s = 100$, and the threshold rises with the stake, from $\beta^* = 0.118$ at $TC_s = 10$ to 0.211 at the base and 0.849 at $TC_s = 100$, reaching 1.92 at $TC_s = 200$ (Appendix A.1.4). No clean proportionality between β^* and TC_s emerges here. At the two highest stakes in the sweep, $TC_s = 100$ and $TC_s = 200$, the flip is of the collapse type, so the benefit is measured against a low-friction state whose triage bill has outgrown the cost of having no program at all. The high-stakes thresholds are real but read differently from the thinning flips below them. Anti-spam friction is therefore most damaging to the vendors with the most to lose, and they stay on the losing side over the widest range of triage burdens.

4.4 Interpreting the Result

The result is counter-intuitive in one respect. Below the threshold the vendor spends less under the friction, yet is worse off. The accounting is direct under a posted bounty. The friction rise pays out fewer bounties, since fewer researchers win, and it cuts the triage bill, since fewer reports arrive. What grows is the expected damage, because the attackers face weaker competition. At low β the damage increase dominates and the vendor loses. The saving grows with β and the damage does not, which is why the sign flips exactly once.

The vendor's private loss understates the social cost. The bounty the vendor saves is a transfer whose disappearance is socially neutral. The added black-hat damage is a real loss borne by the vendor and, through the breach risk it creates, by the software's users. The private profit decline is therefore a lower bound on the social cost of the friction at the coverage margin. What anti-spam delivers in return is triage efficiency, which adds no bug-finding coverage on its own. A filter that removes only the reports that were never going to protect the vendor, and deters no genuine researcher, captures the same triage saving while giving up no coverage, so it dominates a participation barrier that buys the saving by thinning the pool. That is a strong requirement, a condition, not a description of what platforms have available. A wrongful rejection is itself a stochastic participation cost through the entry margin of Section 3.2, so the dominance holds exactly for filters whose false-positive rate on genuine reports keeps the added expected friction below the saving they capture. Blunt barriers persist because building a filter that precise is hard, as Section 2.1's GitGuardian episode shows.

4.5 What a Vendor Can Evaluate

The vendor's cost change decomposes exactly as $\Delta C = TC_s\,\Delta B -$ savings, where $B = K_s(t)\,m\,\mathbb{P}^s_{ib}$ is the mass of severe bugs won by black-hats and the savings term, the fall in triage and bounty outlay, is in the vendor's own records. Those records show report volumes, processing times, and bounty outlays, and the effective triage burden β itself cannot be estimated separately without an estimate of how many reports one unit of search effort generates. Define the substitution rate σ as the ratio of the added black-hat mass to the drop in valid severe reports. No more than the lost reports can be picked up by attackers, so as a statement about the world, $\sigma \le 1$.[*2] The added damage is then at most TC_s times the drop, so the condition

$$\text{savings} \;>\; TC_s \times (\text{drop in valid severe reports})$$

is sufficient for the rule to have helped. It is one-sided, since it stays silent in many cases where the rule did help, but it never says the rule helped when it did not. The coverage loss is a movement in the vendor's own report volume, detectable within tens of observed events (13 for the report-volume drop in the friction rise of Table 1, a rate ratio of 2.52). The damage change is a movement in breach counts, and detecting it there requires an order of magnitude more (112 at the base calibration, a rate ratio of 1.41), which few vendors accumulate quickly. Both figures come from a two-sided Poisson rate-ratio power calculation at $\alpha = 0.05$ and power 0.80 over equal windows, against baselines of 9.25 reports and 0.058 breaches per window, and are lower bounds, since confounding, attribution error, and detection lag worsen the requirement. A vendor's records therefore settle the savings side and the coverage loss. The damage side requires an estimate of what an exploit is worth to an attacker, which no record contains.

5. Discussion and Limitations

5.1 Relation to the Empirical Literature

The friction analysis connects to the elasticity estimate of Sridhar and Ng [2] in two ways. A low median supply elasticity indicates that the reputational component r_s, not the bounty, is the part of researcher compensation that matters, so a policy cost that erodes the participation payoff attacks the margin the empirical literature identifies as dominant. The same estimate is the empirical counterpart of Section 4.2, since even large bounty increases produce little additional supply, so vendors cannot be expected to undo friction through prices. Zrahia et al. [8] document that researchers' net compensation moves with platform conditions, since the COVID-19 supply expansion diluted expected rewards through duplicates, and friction operates on the same object, the compensation a researcher expects net of participation costs. Their two-sided framing explains

[*2] The ratio-form contest inherited from [1] does not impose the bound internally, since its unnormalized first-finder shares sum to slightly more than one. What makes the test convincing is the definition, not the model specification.

© 2026 Information Processing Society of Japan

its institutional origin, since the platform controls the participation rules, not the bounties. Allodi [22] supports the asymmetry behind the result. Underground markets price exploits at levels comparable to or above legitimate channels and refresh slowly, consistent with treating W as stable over the horizon on which platforms adjust their rules.

5.2 Limitations

The model has no submission count of its own.

Gal-Or, Hydari, and Telang count only successful discoveries, so bringing triage into the vendor's profit required two imposed assumptions. We assumed that reports scale with search effort, and that every report costs the same to process. Accordingly, β is an effective burden coefficient, not a directly observed cost per report, and the model does not distinguish the processing cost of low-quality and valid reports, nor can the report-generation rate be estimated separately. The second assumption is the more vulnerable, since dismissing an obviously worthless report is cheaper than verifying a real finding. Section 3.3 bounds the first assumption's curvature. The deeper omission is that the modeled flow contains no low-quality reports. The rules of Section 2.1 were meant to deter spam while keeping genuine researchers, and that benefit never enters the model's ledger.

The effective triage burden is an input, and only the defender side is recoverable.

Which side of the threshold a vendor occupies depends on its own effective triage burden, which we treat as a parameter and do not estimate. The identities of Section 3.2 cut both ways here. The pool size, individual effort, and friction level on the defender side are recoverable from the vendor's valid-report counts and the platform's published policy, but the damage term depends on the attacker's effort, cost, and gain, none of which any record contains. The direction of the loss is identified, but its level is not.

The posted bounty stays posted.

Our main analysis holds the bounty fixed when the platform raises the friction, set for coverage without the triage burden priced in. A vendor that re-optimizes its bounty against the entry margin instead faces no region where the friction pays at the base calibration, because it can thin the pool on its own (Section 4.2), and the alternative order in which the vendor prices against a given pool produces yet another threshold location (Appendix A.2). The answer therefore depends on vendor behavior, and the reader's case is the behavioral question of how quickly real bounty tables move. One caveat cuts against the re-optimizing reading too, since its argument grants the vendor control of report volume through its bounty, while the volume surge followed the availability of AI tools, not any change in bounties [4], [11].

The analysis stays in the severe-focus case and in one vendor–platform pairing.

Friction large enough to push experts toward mixed effort allocations is outside scope, and researchers work on several platforms at once, moving toward better-paying programs [26], so the result concerns a given pairing, not the market-level outcome. The friction also binds on the non-expert pool in reality, and the non-severe terms would move with it in the same direction. We hold those terms constant. By the same token, the persistence of friction regimes across the platforms of Section 2.1 suggests the rules deliver value the model excludes, since vendors are the platform's paying side and can re-list elsewhere.

The hurts-versus-helps answer can flip with the chosen numbers, but the threshold always exists.

At the base calibration the attacker gain $W = 96$, about three times the researcher's total reward, puts black-hats first in most races, against measured exploitation rates of a few percent of disclosed vulnerabilities [27]. Recalibrating W downward to plausible first-find shares lowers the threshold with it, to between 0.03 and 0.20 across shares of 5 to 50 percent, so the verdict at the chosen numbers moves from hurts to helps. A positive threshold exists at every share tested, but the sign at any particular β changes with W. First-to-find is not exploited-in-the-wild, so the implied W and the recalibrated thresholds are lower bounds. The search-space premise is the second weak point. Every result inherits from Gal-Or, Hydari, and Telang the premise that both sides race for the same severe bugs, yet RAND attributes its low collision rates in part to the two sides looking for different vulnerabilities with different techniques [28], and Atefi et al. find that exploited and hunter-reported vulnerabilities differ systematically [29]. Measured collision rates climb with the observation window, from under one percent at ninety days to about forty percent over fourteen years in RAND's data, with public-codebase estimates in between [30], [31], so the objection weakens as the window grows. If the two sides search largely disjoint spaces, or if the race runs on a short horizon, the coverage-loss channel is weaker than modeled. What both weak points put at risk is the hurts-versus-helps verdict at the base calibration of Section 4.1, not the existence of the threshold. Finally, the empirical estimates we rely on predate the AI era, since the Sridhar and Ng and Zrahia et al. samples end in 2020 and 2021, so their use here assumes their direction has persisted.

6. Conclusion

Platform anti-spam rules reach the vendor through two channels. They thin the white-hat researchers who protect the vendor while leaving the attackers, who never participate in the platform, untouched, so coverage falls and breach damage rises. They also shrink the flow of reports the vendor pays to process, so the triage bill falls. Which channel dominates depends on the vendor's effective triage burden, which combines the processing burden of incoming reports with the intensity at which search effort generates reports. Within the tested parameter range the model locates the calibrated threshold at which the sign of the profit effect changes, for the vendor whose posted bounty does not re-adjust when the rules change. For a vendor below the threshold the outcome is a false economy, since it spends less on bounties and

© 2026 Information Processing Society of Japan

less on triage yet is worse off, because the added damage exceeds both of those savings. The harm is easy for a platform to miss, since per-hunter metrics improve as the pool thins. And the vendor's private loss, where it occurs, is a lower bound on the social cost. The comparison favors filters that target low-value submissions directly over blunt participation barriers, provided their false-positive rate stays low enough that the added expected friction does not eat the saving, and vendors should price a platform's friction into their reliance on it, since even an optimized bounty response recovers only part of the coverage. The natural next step is empirical. A vendor's report volume and processing times are measurable from its records, but locating itself against the threshold requires an estimate of the attacker's gain, which no record contains.

Acknowledgments

We thank Professor Kazue Sako and Professor Tatsuya Mori of Waseda University, and the members of their laboratories, for their support of this research through reviews and many discussions of this paper.

References

[1] Esther Gal-Or, Muhammad Zia Hydari, and Rahul Telang. Merchants of vulnerabilities: How bug bounty programs benefit software vendors. *arXiv preprint arXiv:2404.17497*, April 2024. Preprint; subsequently published in Production and Operations Management (2026). Section and page references in this paper follow the arXiv v1 preprint.

[2] Kiran Sridhar and Ming Ng. Hacking for good: Leveraging HackerOne data to develop an economic model of bug bounties. *Journal of Cybersecurity*, 7(1), 2021.

[3] Richard Fang, Rohan Bindu, Akul Gupta, and Daniel Kang. LLM agents can autonomously exploit one-day vulnerabilities. *arXiv preprint arXiv:2404.08144*, 2024.

[4] Bugcrowd. Bugcrowd policy changes to address AI-slop submissions. `https://www.bugcrowd.com/blog/bugcrowd-policy-changes-to-address-ai-slop-submissions/`, March 2026. Accessed: 2026-06-05.

[5] Daniel Stenberg. Death by a thousand slops. `https://daniel.haxx.se/blog/2025/07/14/death-by-a-thousand-slops/`, July 2025. Accessed: 2026-07-10.

[6] Zhen Li and Qi Liao. Harnessing uncertainty in vulnerability market. In *Proceedings of the 27th International Conference on Computer Communications and Networks (ICCCN 2018)*. IEEE, 2018.

[7] Tianlu Zhou, Dan Ma, and Nan Feng. An economic analysis of third-party software reliability improvement using the bug bounty program. In *Proceedings of the 44th International Conference on Information Systems (ICIS 2023)*, 2023.

[8] Aviram Zrahia, Neil Gandal, Sarit Markovich, and Michael Riordan. The simple economics of an external shock to a bug bounty platform. *Journal of Cybersecurity*, 10(1), 2024.

[9] Johannes Wachs. Making markets for information security: The role of online platforms in bug bounty programs. *arXiv preprint arXiv:2204.06905*, 2022.

[10] Jerry Gamblin. 2025 CVE data review. `https://jerrygamblin.com/2026/01/01/2025-cve-data-review/`, January 2026. Accessed: 2026-06-05.

[11] GitHub. Raising the bar: Quality, shared responsibility, and the future of GitHub's bug bounty program. `https://github.blog/security/raising-the-bar-quality-shared-responsibility-and-the-future-of-githubs-bug-bounty-program/`, May 2026. Accessed: 2026-06-05.

[12] Immunefi. Updated submission rules. `https://immunefisupport.zendesk.com/hc/en-us/articles/39568715723409-Updated-Submission-Rules`, October 2025. Accessed: 2026-06-05.

[13] Cantina Documentation. Deposits for bounty submissions. `https://docs.cantina.xyz/for-security-researchers/deposits-for-bounty-submissions`, 2026. Accessed: 2026-06-05.

[14] Code4rena Documentation. Signal and submission limits. `https://docs.code4rena.com/roles/signal`, 2025. Accessed: 2026-06-05.

[15] Sherlock Documentation. Meeting the payout criteria. `https://docs.sherlock.xyz/audits/watsons/meeting-the-payout-criteria`, July 2023. Effective 2023-07-01. Accessed: 2026-06-05.

[16] Node.js Project. New HackerOne signal requirement for vulnerability reports. `https://nodejs.org/en/blog/announcements/hackerone-signal-requirement`, February 2026. Accessed: 2026-07-10.

[17] GitGuardian. Your secrets need a VDP, not just a bug bounty. `https://blog.gitguardian.com/your-secrets-need-a-vdp-not-just-a-bug-bounty/`, February 2026. By Gaetan Ferry. Accessed: 2026-07-10.

[18] Omer Akgul, Taha Eghtesad, Amit Elazari, Omprakash Gnawali, Jens Grossklags, Michelle L. Mazurek, Daniel Votipka, and Aron Laszka. Bug hunters' perspectives on the challenges and benefits of the bug bounty ecosystem. In *Proceedings of the 32nd USENIX Security Symposium (USENIX Security '23)*, pages 2275–2291. USENIX Association, 2023.

[19] Daniel Stenberg. The end of the curl bug-bounty. `https://daniel.haxx.se/blog/2026/01/26/the-end-of-the-curl-bug-bounty/`, January 2026. Accessed: 2026-08-09.

[20] Rainer Böhme. Vulnerability markets: What is the economic value of a zero-day exploit? In *Proceedings of the 22nd Chaos Communication Congress (22C3)*, Berlin, Germany, December 2005.

[21] Karthik Kannan and Rahul Telang. Market for software vulnerabilities? Think Again. *Management Science*, 51(5):726–740, 2005.

[22] Luca Allodi. Economic factors of vulnerability trade and exploitation. In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS '17)*, pages 1483–1499. Association for Computing Machinery, 2017.

[23] Mingyi Zhao, Aron Laszka, and Jens Grossklags. Devising effective policies for bug-bounty platforms and security vulnerability discovery. *Journal of Information Policy*, 7:372–418, 2017.

[24] Aron Laszka, Mingyi Zhao, and Jens Grossklags. Banishing misaligned incentives for validating reports in bug-bounty platforms. In *Proceedings of the 21st European Symposium on Research in Computer Security (ESORICS 2016)*, pages 161–178. Springer, 2016.

[25] N. Gregory Mankiw and Michael D. Whinston. Free entry and social inefficiency. *The RAND Journal of Economics*, 17(1):48–58, 1986.

[26] Thomas Maillart, Mingyi Zhao, Jens Grossklags, and John Chuang. Given enough eyeballs, all bugs are shallow? Revisiting Eric Raymond with bug bounty programs. *Journal of Cybersecurity*, 3(2):81–90, 2017.

[27] Jay Jacobs, Sasha Romanosky, Idris Adjerid, and Wade Baker. Improving vulnerability remediation through better exploit prediction. *Journal of Cybersecurity*, 6(1), 2020.

[28] Lillian Ablon and Andy Bogart. Zero days, thousands of nights: The life and times of zero-day vulnerabilities and their exploits. Technical Report RR-1751-RC, RAND Corporation, 2017.

[29] Soodeh Atefi, Amutheezan Sivagnanam, Afiya Ayman, Jens Grossklags, and Aron Laszka. The benefits of vulnerability discovery and bug bounty programs: Case studies of Chromium and Firefox. In *Proceedings of the ACM Web Conference 2023 (WWW '23)*, pages 2209–2219. Association for Computing Machinery, 2023.

[30] Matthew Finifter, Devdatta Akhawe, and David Wagner. An empirical study of vulnerability rewards programs. In *Proceedings of the 22nd USENIX Security Symposium*, pages 273–288. USENIX Association, 2013.

[31] Trey Herr, Bruce Schneier, and C. Morris. Taking stock: Estimating vulnerability rediscovery. `https://www.belfercenter.org/publication/taking-stock-estimating-vulnerability-rediscovery`, 2017. Technical report, Belfer Center, Harvard Kennedy School.

© 2026 Information Processing Society of Japan

Appendix

A.1 Derivations and Robustness

This appendix restates the derivations the main text defers, working in the multiplicative ratio form of Gal-Or, Hydari, and Telang's Appendix A [1] and in the severe-focus case. The equilibrium is a coupled nonlinear system with no closed form, so the derivations stop at the defining first-order conditions and the entry fixed point, and the reported quantities are obtained by solving those conditions numerically. The procedure is deterministic, and all reported numbers are reproducible from the displayed equations. An independent implementation from the first-order conditions returns the same values (at the base calibration with $\beta = 0.20$, $C = 14.9503$ at the low-friction value and the threshold $\beta^* = 0.2111$). One property of the ratio form should be noted here, since everything below builds on it: the first-finder shares do not sum to one, since each type's denominator omits the focal hacker's own effort. Their total mass runs slightly above one. This is inherited from the source model and affects none of the sign conclusions.

A.1.1 Stage 2: Equilibrium Effort

For the focal expert white-hat (eWHH) and the focal black-hat (BHH), evaluated at the type-symmetric profile, the success probabilities are as in Section 2.2. Differentiating the objectives and imposing symmetry yields the coupled equilibrium conditions

$$c_w\,\alpha_s\,[(n-1)\alpha_s + m\mu_s] = \kappa\,(r_s + p_s),$$
$$c_b\,\mu_s\,[n\alpha_s + (m-1)\mu_s] = \kappa\,W,$$

with $\kappa \equiv K_s(t)(s-1)/s$. The solver evaluates them by multi-start root finding and retains the root continuous with the frictionless equilibrium. Across every parameter set tested, the search returned no second root with positive efforts. The eWHH equilibrium payoff used in Section 3.2 is

$$\pi_W(n; p_s) = K_s(t)\,\mathbb{P}^s_{ie}\,(r_s + p_s) - \tfrac{1}{2}\,c_w\,\alpha_s^2,$$

and the identity $\pi_W = \frac{1}{2}c_w\alpha_s^2$ follows by substituting the eWHH condition into the payoff, and holds to machine precision in every solver state.

A.1.2 Stage 1: The Vendor's Optimal Bounty

The vendor commits to p_s before entry, so its Stage 1 problem is

$$\min_{p_s \geq 0}\; C(p_s,\, n(p_s; c_f))\,,$$

where $n(p_s; c_f)$ is the entry response of Section 3.2. The first-order condition is

$$\frac{\mathrm{d}C}{\mathrm{d}p_s} \;+\; \frac{\partial C}{\partial n}\,\frac{\mathrm{d}n}{\mathrm{d}p_s} = 0,$$

where the first term is the total derivative through the Stage 2 system,

$$\frac{\mathrm{d}C}{\mathrm{d}p_s} = K_s(t)\left[\,m\,TC_s\,\frac{\mathrm{d}\mathbb{P}^s_{ib}}{\mathrm{d}p_s} + n\,\mathbb{P}^s_{ie} + n\,p_s\,\frac{\mathrm{d}\mathbb{P}^s_{ie}}{\mathrm{d}p_s}\,\right] + \beta\,n\,\frac{\mathrm{d}\alpha_s}{\mathrm{d}p_s},$$

and the steering term follows from the entry condition as $\mathrm{d}n/\mathrm{d}p_s = -(\partial\pi_W/\partial p_s)\,/\,(\partial\pi_W/\partial n)$, with all derivatives obtained by implicitly differentiating the Stage 2 conditions, a step Gal-Or, Hydari, and Telang's Appendix A leaves undone. The posted bounty of the main text is the optimum of this problem at $\beta = 0$ at the low-friction value, since the posted bounty is set without the triage burden priced in. The re-optimizing vendor of Section 4.2 solves the full problem at each (β, c_f). The solver locates the optimum by a bounded search guarded by a coarse grid against non-unimodality, with no second local minimum found in practice, and the points where the non-negativity constraint binds are reported with the results.

A.1.3 The Entry Margin

The property that gives the entry margin its structure is that $\pi_W(n; p_s)$ is strictly decreasing in n at any posted bounty. The solver confirms $\pi'_W(n) < 0$ over the operating range at every bounty tested. More can be said analytically. By the identity of Appendix A.1.1, $\pi_W = \frac{1}{2}c_w\alpha_s^2$ exactly, so the sign of $\pi'_W(n)$ at a fixed bounty is the sign of $\alpha'_s(n)$. Total differentiation of the coupled Stage 2 conditions gives $\mathrm{d}\alpha_s/\mathrm{d}n = c_w c_b\,\alpha_s N/\det(J)$, where J is the Jacobian of the Stage-2 first-order system and $\det(J) = 2c_w c_b\left[n(n-1)\alpha_s^2 + 2(m-1)(n-1)\alpha_s\mu_s + m(m-1)\mu_s^2\right]$ is positive for all $n \geq 1$, $m > 1$, and $\mu_s > 0$, and $N = -\alpha_s(B - \mu_s) + \rho\,[(n-1)\alpha_s B + (m-1)\mu_s A]$, with $A = (n-1)\alpha_s + m\mu_s$, $B = n\alpha_s + (m-1)\mu_s$, and $\rho = 1/((n+m)(n+m-1))$. The condition for decline is $\alpha_s(B - \mu_s) > \rho\,[(n-1)\alpha_s B + (m-1)\mu_s A]$. Its left side is positive whenever $m \geq 2$, and its right side is damped by $\rho = O((n+m)^{-2})$, so the decline holds for all large n and can fail only near $n = 1$ when $\mu_s \gg \alpha_s$. On the base-calibration test grid of sixteen thousand points, the condition holds at 99.9 percent of points, the symbolic sign agrees with finite differences everywhere, and the failure region is confined to $p_s \leq 0.5$ and $n \in [1, 1.36]$, with upward deviations of at most 2.2×10^{-6}. Where the decline holds, the equilibrium condition $\pi_W(n^*; p_s) = c_f$ therefore has at most one interior solution, and the implicit-function theorem gives the participation response $\mathrm{d}n^*/\mathrm{d}c_f = 1/\pi'_W(n^*) < 0$. Combining the entry condition with the identity of Appendix A.1.1 gives each survivor's effort in closed form, $\alpha_s^* = \sqrt{2\,c_f/c_w}$, independent of pool size, attacker count, and breach cost. The main text treats the pool size as continuous, the standard large-market approximation. With integer entry the condition reads $\pi_W(n^*; p_s) \geq c_f > \pi_W(n^* + 1; p_s)$, with the same sign throughout.

© 2026 Information Processing Society of Japan

Table A·1 Robustness of the threshold across perturbations of the base calibration ($m = 10$, $K_s = 0.5$, $c_w = c_b = 2$, $r_s = 10$, $W = 96$, $TC_s = 30$). $\Delta C(0)$ is the cost increase from the friction rise at zero triage burden. Mechanism T is thinning (the thinned pool survives) and C is collapse (it does not). The $TC_s = 200$ row is from the high-stakes sweep of Section 4.3.

Perturbation	$\Delta C(0)$	β^*	Mechanism
base calibration	+1.177	0.211	T
$W = 48$	+3.389	0.402	C
$W = 200$	+1.124	0.167	T
$r_s = 2$	+0.639	0.177	T
$r_s = 30$	+3.824	0.376	C
$TC_s = 10$	+0.512	0.118	T
$TC_s = 100$	+11.008	0.849	C
$TC_s = 200$	+32.651	1.916	C
$K_s = 0.2$	+0.288	0.137	T
$K_s = 0.9$	+2.337	0.266	T
$c_b = 1.2$	+0.897	0.176	T
$c_w = 1.2$	+3.217	0.275	C
$c_w = 3$	+0.670	0.206	T
$W = 150,\ r_s = 5$	+0.988	0.169	T

A.1.4 Robustness of the Threshold

The core result, that a friction rise flips from hurting to helping the posted-bounty vendor at a threshold triage burden, was verified at the base calibration and across thirteen perturbations, twelve changing a single parameter and one changing two. Table A·1 reports, for each parameter set, the cost increase from the friction rise at zero triage burden, where a positive value means friction lowers profit, the threshold β^*, and the mechanism. The cost increase and the threshold are positive in every case, and every flip is guarded by a strictly negative region above it. The threshold rises with the per-bug stake TC_s, the quantitative form of the high-stakes result of Section 4.3.

A.2 The Pool-Taking Order

An alternative timing of the game lets the vendor price against a pool it takes as given, closing the pool with the same entry condition evaluated at the vendor's optimal response to each pool size. That order reverses the base model's Stackelberg sequence, since the vendor's price then follows the pool instead of leading it, which is why the main text uses the vendor-first order. We record what the pool-taking order produces, because the threshold's location is specification-dependent and the reader should see the range. Under that order the break-even point between pools of 3 and 15, the pool values of that formulation, sits at $\beta^* = 0.656$ at the base calibration, against 0.211 under the posted-bounty order of the main text and no region where the friction pays at all for the continuously re-optimizing vendor. The three specifications agree on the two channels and on the sign structure at low triage burden. They differ on where, and whether, the sign changes.

One caveat applies to both orders of the main text. The re-optimizing argument grants the vendor control of report volume through its bounty, but the AI-era flood broke that link, since the volume surge followed the availability of AI tools, not any change in bounties [4], [11]. A model with an exogenous spam flow, which no specification here contains, is what would settle the question.

© 2026 Information Processing Society of Japan